

Práctica

Disco duro virtual seguro

Seguridad en el diseño de software

Autor: Georg Usin Osipov



INDICE

1. Introducción.....	3
2. Descripción.....	4
2.1 Funcionalidades Implementadas.....	4
2.2 Planificación y División del Trabajo.....	5
2.3 Expectativas de Seguridad y Privacidad.....	6
2.3.1 Elementos Criptográficos Empleados.....	6
2.3.2 Límites de Seguridad.....	6
3. Conclusión.....	7
3.1 ¿Que se ha realizado?.....	7
3.2 Aspectos Positivos y Relevantes.....	7
3.3 Posibles Trabajos Futuros.....	7

1. Introducción

El objetivo principal de este proyecto es implementar un sistema de almacenamiento virtual en la nube bajo una arquitectura Cliente - Servidor, priorizando la confidencialidad, integridad y seguridad del sistema.

Para ello, se ha utilizado un framework base proporcionado por el profesor que ha sido extendido hasta convertirse en un entorno de alta seguridad. A parte de cumplir con todos los requisitos obligatorios de la práctica, el sistema implementa mejoras como cifrado punto a punto, firmas digitales e incorporación de clave pública en la autenticación de usuarios, entre otros.

2. Descripción

2.1 Funcionalidades Implementadas

El proyecto cumple con todas las características obligatorias y varios desafíos adicionales.

Nota: No se incluye la columna autorías porque todo está realizado por la misma persona.

Funcionalidad	Tipo	Descripción
Arquitectura Cliente Servidor	Obligatorio	Modelo concurrente mediante HTTP
Autenticación Segura	Obligatorio	Gestión de contraseñas mediante derivación segura (Argon2id) y control de sesiones mediante tokens.
Transporte Seguro	Obligatorio	Toda la comunicación se realiza sobre protocolo TLS (HTTPS) mitigando MitM.
Cifrado en Descanso	Obligatorio	Base de datos almacena la información cifrada mediante AES-256-CTR protegido por una master key que ingresa el administrador al iniciar el servidor.
Gestión de Ficheros	Obligatorio	Funciones para crear, listar, descargar y borrar archivos/directorios de forma virtualizada sin comprometer el sistema host.
Cifrado Punto a Punto	Opcional	Cifrado AES-256 realizado localmente en el cliente derivando una clave secreta a partir de la contraseña del usuario
Gestión de metadatos	Opcional	Captura de permisos, fechas de modificación, peso y sistema operativo integrados en el payload del fichero.
Categorías y Tags	Opcional	Etiquetado de ficheros en el momento de la subida permitiendo el filtrado y búsqueda en el directorio remoto.
Gestión de diferentes roles de usuario	Opcional	Se ha añadido el rol administrador y usuario. El primer usuario registrado recibe el rol admin, el resto reciben el rol user.
Autenticación con Clave Pública	Opcional	Generación y almacenamiento seguro de identidades criptográficas (Ed25519 y X25519) en un “Cloud Wallet Local” protegido por la clave del usuario.
Firma Digital	Opcional	Garantiza el origen en la subida de datos empleando firmas Ed25519 sobre contenido cifrado.
Mensajería privada	Opcional	Sistema de comunicación asíncrono entre usuarios. Intercambio de claves mediante X25519.
Logging Remoto	Opcional	Registro centralizado en el servidor de eventos críticos invocados por el cliente para auditorías.
Copia de seguridad Backup	Opcional	Extracción remota del estado íntegro de la base de datos y envío al administrador sin interrumpir servicio.
Anti-Replay (Nonces)	Extra	Integración de nonces y timestamps en las firmas digitales para mitigar Replay attacks.

La gestión de diferentes roles se ha implementado después de la copia de seguridad, la única diferencia entre un administrador y un usuario es la capacidad de poder generar una copia de seguridad a través del menú.

2.2 Planificación y División del Trabajo

El proyecto se ha realizado siguiendo una metodología ágil que segmenta el trabajo por fases:

Fase	Trabajo realizado	Tiempo
Fase 1	Entender el framework base, implementar mecanismo de autenticación seguro y HTTPs.	2 semanas
Fase 2	Implementar cifrado en descanso y gestión de ficheros.	1 semanas
Fase 3	Implementar cifrado punto a punto, gestión de metadatos y gestión de categorías.	1 semanas
Fase 4	Implementar cambios recomendados en la revisión de la práctica, clave pública en autenticación y firma digital.	2 semanas
Fase 5	Implementar sistema de comunicación privado, logging, backups.	2 semanas
Fase 6	Implementar nonces como para mejorar seguridad, realizar memoria y video.	2 semanas

La primera revisión se realizó después de la fase 3.

2.3 Expectativas de Seguridad y Privacidad

2.3.1 Elementos Criptográficos Empleados

AES-256: Utilizado para el cifrado de ficheros y mensajes. AES ofrece un balance perfecto entre extrema seguridad y altísimo rendimiento por hardware.

Ed25519: Esquema de curva elíptica utilizado para firma digital. Se eligió por su inmunidad a los timing attacks y por no requerir un generador de número aleatorios en el proceso de firma.

X25519 (ECDH): Empleado en el sistema de mensajería para el intercambio de claves. Alice y Bob combinan sus claves para derivar matemáticamente un secreto compartido que cifra sus mensajes y que el servidor es incapaz de calcular.

Derivación de llaves (Argon2id): Utilizado para estirar la entropía de la contraseña del usuario y generar claves AES E2E de forma determinista y segura frente a ataques de fuerza bruta.

Nonces y timestamps (Anti-Replay): Todas las firmas digitales Ed25519 engloban no solo los datos cifrados, sino también un Nonce y un Timestamps para prevenir ataques de repetición lógica en la capa de aplicación.

2.3.2 Límites de Seguridad

El sistema está diseñado para ser altamente resiliente, pero existen condiciones o vectores fuera del modelo de amenaza contemplado:

Compromiso del Cliente: Si el ordenador del usuario está infectado con keyloggers o malware, la seguridad E2E se rompe, ya que la contraseña y la wallet local cifrada serían vulnerables antes de aplicar las protecciones criptográficas.

Disponibilidad frente a ataques DDoS: Aunque la información se mantiene segura y cifrada, la arquitectura actual no posee balanceadores de carga avanzados o protección a nivel red frente a denegaciones de servicio distribuidas, por lo que el servidor podría caer afectando la disponibilidad.

Certificados TLS Autofirmados: En el entorno de desarrollo se puede obviar la verificación del certificado TLS. En un entorno de producción, esto podría permitir ataques MitM en la capa de transporte si un atacante logra posicionarse en la red y el usuario acepta el certificado sin verificar.

Ataques de Reenvío: El protocolo TLS protege contra ataques de repetición en la red. Sin embargo, para mitigar que un atacante interno reenvíe mensajes cifrados y firmados válidos, se ha incorporado la firma conjunta de un nonce y timestamp. El cliente receptor mantiene un registro activo de nonces ya procesados, descartando cualquier mensaje con nonce repetido.

3. Conclusión

3.1 ¿Que se ha realizado?

Se ha diseñado y desarrollado un entorno de almacenamiento y comunicación seguro a partir de un framework base en lenguaje Go sobre protocolos HTTPS y bases de datos transaccionales, fortificando cada capa lógica con criptografía moderna de altas prestaciones.

3.2 Aspectos Positivos y Relevantes

El aspecto más destacable del proyecto es su enfoque de Confianza cero frente al propio servidor. Gracias a la implementación conjunta de cifrado E2E y las claves de curvas elípticas, el servidor queda relegado a actuar como mero almacén ciego de datos ofuscados. Incluso en el escenario en el que la base de datos y la clave maestra del servidor fueran filtradas, los atacantes solo obtendrían ruido criptográfico inútil, preservando así la total privacidad de los usuarios. La adición de la firma Ed25519 refuerza el modelo asegurando la integridad estricta del autor del dato.

3.3 Posibles Trabajos Futuros

Evolucionar interfaz de la aplicación para que deje de ser un CLI y tenga un aspecto mas moderno y mejorar la experiencia del usuario. Ampliar la aplicación con las funcionalidades opcionales de compartir ficheros con otros usuario, haciendo así una aplicación similar a DropBox en la que si que es importante tener en cuenta los ataques de denegación de servicio y trabajar ese aspecto.

Enlace al video presentación de la práctica realizada:

<https://www.youtube.com/watch?v=3JSGJbBLLks>